

Explainable Phishing Risk Warnings in PhishGuard

Prepared by

Luis Nicaragua
Research and Documentation
PhishGuard Team

Introduction

PhishGuard is a cybersecurity-focused web application concept designed to help users identify suspicious emails, text messages, and URLs through explainable phishing risk analysis and cybersecurity awareness guidance. As the project continues to develop, one important area of focus is how scan results should be explained to users. A phishing tool is more useful when it does not only tell the user that something is suspicious, but also explains why the warning matters.

This research paper focuses on the proposed Bait Breakdown feature. Bait Breakdown would expand PhishGuard's Sonar Analysis Log by giving users clear explanations for each detected warning. Instead of only showing technical labels such as "Missing HTTPS," "URL Shortener Detected," or "Suspicious Keyword Found," the feature would explain what was detected, why it may be risky, and what action the user should take next.

The purpose of this research is to support PhishGuard's goal of explainable phishing risk analysis. The sources selected for this paper focus on explainable phishing warnings, cybersecurity warning explanations, and phishing warning design. Together, they help show how PhishGuard can make scan results easier for users to understand and more useful for safer digital decision-making.

Research Purpose

The purpose of this research is to answer the following question:

How can PhishGuard explain phishing scan warnings in a way that helps users understand risk and make safer decisions?

This question is important because users may not understand technical warning labels on their own. For example, a user may see that a link has a URL shortener or missing HTTPS, but they may not understand why that matters. Bait Breakdown would help solve this problem by translating scan results into simple, user-facing explanations.

This research supports three main goals for PhishGuard:

First, it supports clearer warning explanations. Users should understand what PhishGuard detected and why that warning matters.

Second, it supports better user decision-making. Users should receive practical guidance before clicking a suspicious link or entering personal information.

Third, it supports stronger documentation and feature planning. The team can use this research to describe how Bait Breakdown should work and how it connects to the project's overall scope.

Source 1: “Explain, Don’t Just Warn!” A Real-Time Framework for Generating Phishing Warnings with Contextual Cues

The first source supports the main idea behind Bait Breakdown. The paper argues that many anti-phishing tools provide generic warnings that tell users something is dangerous without explaining why. This is a problem because users may not develop the understanding needed to recognize phishing indicators on their own.

The paper introduces PhishXplain, a system designed to generate explainable phishing warnings with contextual cues. Instead of only warning users that a site is malicious, the system highlights suspicious features and explains why those features matter. This connects directly to PhishGuard because Bait Breakdown has a similar purpose. It would help users understand the specific warnings shown in the Sonar Analysis Log.

For PhishGuard, this source supports the idea that scan warnings should be more than labels. A warning such as “Suspicious Redirect” should include a short explanation that tells the user why redirects can be risky. A warning such as “URL Shortener Detected” should explain that shortened links can hide the real destination of a website.

This source contributes to the research by supporting the need for explainable phishing warnings. It shows that users benefit when warnings include context and help them understand the signs of phishing. This can help PhishGuard become an awareness tool, not just a scanner.

Source 2: “SPLAIN: Augmenting Cybersecurity Warnings with Reasons and Data”

The second source supports how PhishGuard should structure its warning explanations. SPLAIN focuses on converting cybersecurity warning data into clear natural language explanations. This is important because security warnings can be confusing when they only show technical information without explaining the meaning behind the warning.

This source supports the idea that warnings should explain both the “how” and the “why” behind an alert. For PhishGuard, this connects strongly to the Bait Breakdown format. Each warning explanation should follow a consistent structure so users know what to expect.

A useful structure for Bait Breakdown would be:

What was detected?

Why is it risky?

What should the user do next?

This structure would help make the Sonar Analysis Log easier to understand. For example, if the scan detects missing HTTPS, Bait Breakdown could explain that the site may not be using a secure connection and that the user should avoid entering sensitive information. If the scan detects a suspicious keyword, the explanation could state that phishing links sometimes use urgent or deceptive wording to pressure users.

This source contributes to the research by supporting consistency in warning explanations. If every warning follows the same format, the user experience becomes clearer and more predictable. This also helps the documentation team because the same structure can be used for feature descriptions, acceptance criteria, and user-facing text.

Source 3: “Let Warnings Interrupt the Interaction and Explain: Designing and Evaluating Phishing Email Warnings”

The third source supports the design and user experience side of phishing warnings. This source focuses on the idea that warnings should interrupt risky behavior and explain the danger before users continue. Although the paper focuses on phishing email warnings, the same concept can apply to PhishGuard’s URL scanning and scan result explanations.

This is important because a warning is only useful if users notice it, understand it, and know what action to take. If a warning appears too late, is too vague, or is too difficult to understand, users may ignore it. PhishGuard should avoid this problem by making its scan results clear and actionable.

For Bait Breakdown, this source supports the idea that warnings should be placed where users can use them effectively. The explanations could appear directly under each Sonar Analysis Log warning or as expandable sections. This would allow users to see the warning title first and then open the explanation if they want more detail.

This source contributes to the research by showing that warning design affects user decisions. For PhishGuard, this means the Bait Breakdown feature should not only focus on what the warning says, but also how the warning is displayed. The team should consider whether explanations are visible immediately, expandable, or connected to the final risk score.

Connection to Bait Breakdown

The three sources all support Bait Breakdown from different angles.

“Explain, Don’t Just Warn!” supports the reason for the feature. It shows that users need contextual explanations, not just generic warnings.

“SPLAIN” supports the structure of the feature. It helps justify a consistent explanation format that includes what was detected, why it matters, and what action the user should take.

“Let Warnings Interrupt the Interaction and Explain” supports the design of the feature. It shows that warning placement, wording, and timing can affect whether users understand and respond to a warning.

Together, these sources help define Bait Breakdown as a research-supported feature recommendation for PhishGuard. The feature would improve the current Sonar Analysis Log by making warnings more understandable and useful for users.

Proposed Bait Breakdown Warning Format

Based on the research, Bait Breakdown should use a simple and repeatable format for each scan warning.

Warning Title

This identifies the detected issue.

Example: URL Shortener Detected

What Was Detected

This explains what PhishGuard found in the scan.

Example: The URL appears to use a shortened link.

Why It May Be Risky

This explains the risk in simple language.

Example: Shortened links can hide the real destination of a website, making it harder for users to know where the link will take them.

Recommended Action

This gives the user a safe next step.

Example: Do not open the link unless you trust the sender or can verify the destination.

This structure supports PhishGuard’s purpose because it turns technical scan results into user-friendly explanations.

Sample Bait Breakdown Entries

Missing HTTPS

What was detected:

The scanned URL does not appear to use HTTPS.

Why it may be risky:

HTTPS helps protect information sent between the user and the website. A missing HTTPS connection may be a warning sign, especially if the site asks for personal information, passwords, or payment details.

Recommended action:

Avoid entering sensitive information on the site. Visit the official website directly if you need to access the service.

URL Shortener Detected

What was detected:

The scanned URL appears to use a shortened link.

Why it may be risky:

Shortened links can hide the real destination of a website. Attackers may use them to make a suspicious link look less obvious.

Recommended action:

Do not click the link unless you trust the sender or can preview the final destination.

Suspicious Keyword Found

What was detected:

The URL or message contains words that may be commonly used in phishing attempts.

Why it may be risky:

Phishing messages often use urgent or deceptive words to pressure users into clicking links or sharing information.

Recommended action:

Be cautious before interacting with the link. Verify the message through an official source.

Suspicious Redirect

What was detected:

The URL may send the user through a redirect before reaching the final destination.

Why it may be risky:

Redirects can be used to hide the final website location or send users to a suspicious page.

Recommended action:

Avoid opening the link if the destination is unclear. Visit the official website directly instead.

Excessive URL Length

What was detected:

The scanned URL is unusually long or complex.

Why it may be risky:

Long URLs can make it difficult to identify the real domain or destination. Attackers may use long URLs to hide suspicious parts of a link.

Recommended action:

Check the main website domain carefully before clicking. Do not open the link if the destination looks unfamiliar.

How This Supports PhishGuard Documentation

This research supports the documentation work for PhishGuard by giving the team a clear explanation model for Bait Breakdown. The feature can be documented as a planned improvement to the Sonar Analysis Log that supports explainable phishing risk analysis.

The research also supports future user stories and acceptance criteria. For example, a user story could state:

As a user, I want to understand why a URL was flagged as suspicious so that I can make a safer decision before opening it.

Possible acceptance criteria could include:

The feature displays a warning title for each detected issue.

The feature explains what was detected.

The feature explains why the warning may be risky.

The feature provides a recommended action.

The explanation is written in simple language for non-technical users.

The explanation connects to the scan result or risk score.

How This Supports the Prototype

This research does not require PhishGuard to become a more advanced detection system immediately. Instead, it supports improving how scan results are presented to users.

If the prototype already includes a Sonar Analysis Log, Bait Breakdown could build on that section by adding short explanations. This could be done directly under each warning or through expandable sections. The team can decide which version best fits the interface.

This keeps the feature realistic for the current project scope. It supports user understanding and safer decision-making without requiring the team to build a complex artificial intelligence system or enterprise-level security product.

Conclusion

The new research supports the development of explainable phishing risk warnings in PhishGuard. The three sources show that warnings should not only alert users, but also explain why something may be risky and what the user should do next.

For PhishGuard, this supports the Bait Breakdown feature as a practical improvement to the Sonar Analysis Log. Bait Breakdown would help users understand scan warnings such as missing HTTPS, URL shorteners, suspicious keywords, redirects, and long URLs. By using a consistent explanation format, the feature can make scan results easier to understand and more useful for safer digital decision-making.

Overall, this research strengthens PhishGuard's purpose as an explainable phishing awareness tool. It connects the project's technical scan results to user education, clear documentation, and future prototype planning.

Works Cited

- Buono, Paolo, Giuseppe Desolda, Francesco Greco, and Antonio Piccinno. "Let Warnings Interrupt the Interaction and Explain: Designing and Evaluating Phishing Email Warnings." *Extended Abstracts of the 2023 CHI Conference on Human Factors in Computing Systems*, Association for Computing Machinery, 2023, doi.org/10.1145/3544549.3585802.
- Kazakova, Vera A., Jena D. Hwang, Bonnie J. Dorr, Yorick Wilks, J. Blake Gage, Alex Memory, and Mark A. Clark. "SPLAIN: Augmenting Cybersecurity Warnings with Reasons and Data." *arXiv*, 2023, arxiv.org/abs/2311.11215.
- Roy, Sayak Saha, Cesar Torres, and Shirin Nilizadeh. "'Explain, Don't Just Warn!': A Real-Time Framework for Generating Phishing Warnings with Contextual Cues." *arXiv*, 2025, arxiv.org/abs/2505.06836.